

Enumeration

🔥 cyberforge.blog/writeups/GOAD/Enumeration

Initial nmap scan

First we start with an Nmap scan on the 3 machines

- KINGSLANDING - 192.168.56.10
- WINTERFELL (192.168.56.11)
- CASTELBLACK (192.168.56.22)

```
PORT      STATE  SERVICE      VERSION
53/tcp    open   domain        Simple DNS Plus
80/tcp    open   http          Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: IIS Windows Server
88/tcp    open   kerberos-sec  Microsoft Windows Kerberos (server time: 2023-12-24 17:45:15Z)
135/tcp   open   msrpc         Microsoft Windows RPC
139/tcp   open   netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open   ldap          Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default-First-Site-Name)
|_ ssl-cert: Subject: commonName=kingslanding.sevenkingdoms.local
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:kingslanding.sevenkingdoms.local
|_ Not valid before: 2023-12-24T16:50:27
|_ Not valid after: 2024-12-23T16:50:27
|_ ssl-date: 2023-12-24T17:46:11+00:00; 0s from scanner time.
445/tcp   open   microsoft-ds?
464/tcp   open   kpasswd5?
593/tcp   open   ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open   ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default-First-Site-Name)
|_ ssl-cert: Subject: commonName=kingslanding.sevenkingdoms.local
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:kingslanding.sevenkingdoms.local
|_ Not valid before: 2023-12-24T16:50:27
|_ Not valid after: 2024-12-23T16:50:27
|_ ssl-date: 2023-12-24T17:46:11+00:00; 0s from scanner time.
3268/tcp  open   ldap          Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default-First-Site-Name)
|_ ssl-cert: Subject: commonName=kingslanding.sevenkingdoms.local
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:kingslanding.sevenkingdoms.local
|_ Not valid before: 2023-12-24T16:50:27
|_ Not valid after: 2024-12-23T16:50:27
|_ ssl-date: 2023-12-24T17:46:11+00:00; 0s from scanner time.
```

```

3269/tcp open      ssl/ldap      Microsoft Windows Active Directory LDAP (Domain:
sevenkingdoms.local0., Site: Default-First-Site-Name)
|_ssl-date: 2023-12-24T17:46:11+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=kingslanding.sevenkingdoms.local
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1.1:<unsupported>,
DNS:kingslanding.sevenkingdoms.local
| Not valid before: 2023-12-24T16:50:27
|_Not valid after: 2024-12-23T16:50:27
3389/tcp open      ms-wbt-server Microsoft Terminal Services
| ssl-cert: Subject: commonName=kingslanding.sevenkingdoms.local
| Not valid before: 2023-12-23T15:42:17
|_Not valid after: 2024-06-23T15:42:17
|_ssl-date: 2023-12-24T17:46:11+00:00; 0s from scanner time.
5985/tcp open      http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
5986/tcp open      ssl/http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
| ssl-cert: Subject: commonName=VAGRANT
| Subject Alternative Name: DNS:VAGRANT, DNS:vagrant
| Not valid before: 2023-12-23T07:31:02
|_Not valid after: 2026-12-22T07:31:02
|_http-server-header: Microsoft-HTTPAPI/2.0
|_ssl-date: 2023-12-24T17:46:11+00:00; 0s from scanner time.
| tls-alpn:
|_ http/1.1
9389/tcp open      mc-nmf        .NET Message Framing
40754/tcp filtered unknown
47001/tcp open      http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
49664/tcp open      msrpc         Microsoft Windows RPC
49665/tcp open      msrpc         Microsoft Windows RPC
49666/tcp open      msrpc         Microsoft Windows RPC
49667/tcp open      msrpc         Microsoft Windows RPC
49671/tcp open      msrpc         Microsoft Windows RPC
49674/tcp open      ncacn_http    Microsoft Windows RPC over HTTP 1.0
49675/tcp open      msrpc         Microsoft Windows RPC
49677/tcp open      msrpc         Microsoft Windows RPC
49680/tcp open      msrpc         Microsoft Windows RPC
49690/tcp open      msrpc         Microsoft Windows RPC
49695/tcp open      msrpc         Microsoft Windows RPC
49727/tcp open      msrpc         Microsoft Windows RPC
Service Info: Host: KINGSLANDING; OS: Windows; CPE: cpe:/o:microsoft:windows

```

We note the existence of 2 domains (sevenkingdoms.local and north.sevenkingdoms.local) and 3 machines (KINGSLANDING, WINTERFELL and CASTELBLACK).

We also note the presence of a MSSQL and HTTP service on CASTELBLACK.

SMB and RPC enumeration

We can enumerate the different machines with crackmapexec:

```
crackmapexec smb 192.168.56.10-22 -u "Guest" -p ""
SMB      192.168.56.11  445  WINTERFELL  [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL)
(domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB      192.168.56.22  445  CASTELBLACK [*] Windows 10.0 Build 17763 x64 (name:CASTELBLACK)
(domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB      192.168.56.10  445  KINGSLANDING [*] Windows 10.0 Build 17763 x64 (name:KINGSLANDING)
(domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB      192.168.56.11  445  WINTERFELL  [-] north.sevenkingdoms.local\Guest:
STATUS_ACCOUNT_DISABLED
SMB      192.168.56.22  445  CASTELBLACK  [+] north.sevenkingdoms.local\Guest:
SMB      192.168.56.10  445  KINGSLANDING [-] sevenkingdoms.local\Guest:
STATUS_ACCOUNT_DISABLED
}
```

► Crackmapexec with Guest account

The Guest account is disabled on WINTERFELL and KINGSLANDING but is enabled on CASTELBLACK

We continue the enumeration with enum4linux only initially on CASTELBLACK:

```
enum4linux north.sevenkingdoms.local
```

```
===== ( Target Information )=====
```

```
Target ..... north.sevenkingdoms.local
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

<SNIP>

```
===== ( Session Check on north.sevenkingdoms.local )=====
```

```
[+] Server north.sevenkingdoms.local allows sessions using username '', password ''
```

```
===== ( Users on north.sevenkingdoms.local )=====
```

```
index: 0x188d RID: 0x456 acb: 0x00000210 Account: arya.stark Name: (null)
Desc: Arya Stark
index: 0x1892 RID: 0x45b acb: 0x00010210 Account: brandon.stark Name: (null)
Desc: Brandon Stark
index: 0x16fa RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc:
Built-in account for guest access to the computer/domain
```

index: 0x1894 RID: 0x45d acb: 0x00000210 Account: hodor Name: (null) Desc: Brainless Giant
index: 0x1897 RID: 0x460 acb: 0x00000210 Account: jeor.mormont Name: (null) Desc: Jeor Mormont
index: 0x1895 RID: 0x45e acb: 0x00040210 Account: jon.snow Name: (null) Desc: Jon Snow
index: 0x1893 RID: 0x45c acb: 0x00000210 Account: rickon.stark Name: (null) Desc: Rickon Stark
index: 0x1896 RID: 0x45f acb: 0x00000210 Account: samwell.tarly Name: (null) Desc: Samwell Tarly (Password : Heartsbane)
index: 0x1891 RID: 0x45a acb: 0x00000210 Account: sansa.stark Name: (null) Desc: Sansa Stark
index: 0x1898 RID: 0x461 acb: 0x00000210 Account: sql_svc Name: (null) Desc: sql service

<SNIP>

[+] Retrieved partial password policy with rpcclient:

Password Complexity: Disabled
Minimum Password Length: 5

<SNIP>

[+] Getting domain group memberships:

Group: 'Stark' (RID: 1106) has member: NORTH\arya.stark
Group: 'Stark' (RID: 1106) has member: NORTH\eddard.stark
Group: 'Stark' (RID: 1106) has member: NORTH\catelyn.stark
Group: 'Stark' (RID: 1106) has member: NORTH\robb.stark
Group: 'Stark' (RID: 1106) has member: NORTH\sansa.stark
Group: 'Stark' (RID: 1106) has member: NORTH\brandon.stark
Group: 'Stark' (RID: 1106) has member: NORTH\rickon.stark
Group: 'Stark' (RID: 1106) has member: NORTH\hodor
Group: 'Stark' (RID: 1106) has member: NORTH\jon.snow
Group: 'Night Watch' (RID: 1107) has member: NORTH\jon.snow
Group: 'Night Watch' (RID: 1107) has member: NORTH\samwell.tarly
Group: 'Night Watch' (RID: 1107) has member: NORTH\jeor.mormont
Group: 'Domain Computers' (RID: 515) has member: NORTH\CASTELBLACK\$
Group: 'Mormont' (RID: 1108) has member: NORTH\jeor.mormont
Group: 'Domain Guests' (RID: 514) has member: NORTH\Guest
Group: 'Group Policy Creator Owners' (RID: 520) has member: NORTH\Administrator
Group: 'Domain Users' (RID: 513) has member: NORTH\Administrator
Group: 'Domain Users' (RID: 513) has member: NORTH\vagrant
Group: 'Domain Users' (RID: 513) has member: NORTH\krbtgt
Group: 'Domain Users' (RID: 513) has member: NORTH\SEVENKINGDOMS\$
Group: 'Domain Users' (RID: 513) has member: NORTH\arya.stark
Group: 'Domain Users' (RID: 513) has member: NORTH\eddard.stark
Group: 'Domain Users' (RID: 513) has member: NORTH\catelyn.stark
Group: 'Domain Users' (RID: 513) has member: NORTH\robb.stark
Group: 'Domain Users' (RID: 513) has member: NORTH\sansa.stark

Group: 'Domain Users' (RID: 513) has member: NORTH\brandon.stark
 Group: 'Domain Users' (RID: 513) has member: NORTH\rickon.stark
 Group: 'Domain Users' (RID: 513) has member: NORTH\hodor
 Group: 'Domain Users' (RID: 513) has member: NORTH\jon.snow
 Group: 'Domain Users' (RID: 513) has member: NORTH\samwell.tarly
 Group: 'Domain Users' (RID: 513) has member: NORTH\jeor.mormont
 Group: 'Domain Users' (RID: 513) has member: NORTH\sql_svc

We have an initial list of users thanks to the RPC enumeration given by enum4linux:

Guest
 arya.stark
 sansa.stark
 brandon.stark
 rickon.stark
 hodor
 jon.snow
 samwell.tarly
 jeor.mormont
 sql_svc

We also have the current password policy in place in the domain. 5 character minimum and no complexity. This is very weak.

Finally, we also note a password in a description: Samwell Tarly (Password: Heartsbane).

We then confirm that a all share is available in READ/WRITE with anonymous logon on the **CASTELBLACK** server:

```
crackmapexec smb 192.168.56.22 -u "Guest" -p "" --shares
SMB      192.168.56.22  445  CASTELBLACK  [*] Windows 10.0 Build 17763 x64 (name:CASTELBLACK)
(domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB      192.168.56.22  445  CASTELBLACK  [+] north.sevenkingdoms.local\Guest:
SMB      192.168.56.22  445  CASTELBLACK  [+] Enumerated shares
SMB      192.168.56.22  445  CASTELBLACK  Share      Permissions      Remark
SMB      192.168.56.22  445  CASTELBLACK  -----
SMB      192.168.56.22  445  CASTELBLACK  ADMIN$      -----      Remote Admin
SMB      192.168.56.22  445  CASTELBLACK  all          READ,WRITE      Basic RW share for all
SMB      192.168.56.22  445  CASTELBLACK  C$           Default share
SMB      192.168.56.22  445  CASTELBLACK  IPC$         READ            Remote IPC
SMB      192.168.56.22  445  CASTELBLACK  public       Basic Read share for all domain users
```

▼ Output Crackmapexec

```
crackmapexec smb 192.168.56.22 -u "Guest" -p "" --shares
SMB      192.168.56.22  445  CASTELBLACK  [*] Windows 10.0 Build 17763
x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False)
(SMBv1:False)
SMB      192.168.56.22  445  CASTELBLACK  [+]
north.sevenkingdoms.local\Guest:
SMB      192.168.56.22  445  CASTELBLACK  [+] Enumerated shares
SMB      192.168.56.22  445  CASTELBLACK  Share      Permissions
```

Remark					
SMB	192.168.56.22	445	CASTELBLACK	-----	-----

SMB	192.168.56.22	445	CASTELBLACK	ADMIN\$	
Remote Admin					
SMB	192.168.56.22	445	CASTELBLACK	all	READ,WRITE
Basic RW share for all					
SMB	192.168.56.22	445	CASTELBLACK	C\$	
Default share					
SMB	192.168.56.22	445	CASTELBLACK	IPC\$	READ
Remote IPC					
SMB	192.168.56.22	445	CASTELBLACK	public	
Basic Read share for all domain users					

We have initial access to the north.sevenkingdoms.local domain with the samwell.tarly account and the password Heartsbane.